BCSE-1501
Network Security

Dr. Arvind Prasad
Department of CEA
GLA University, Mathura

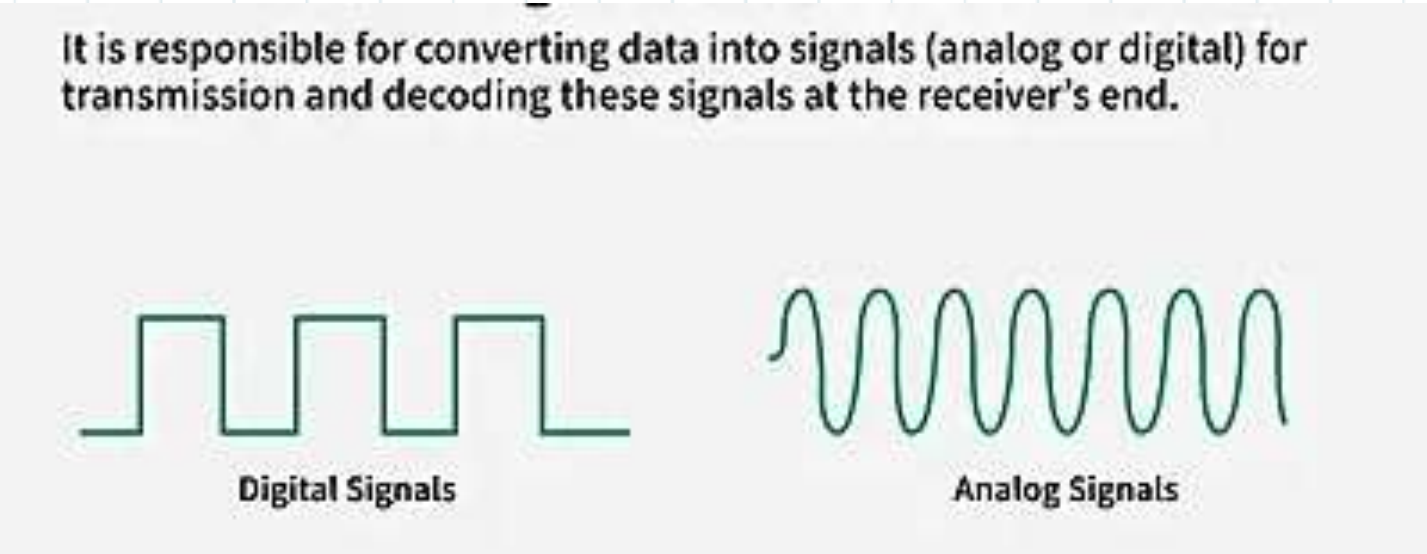
Network Vulnerabilities

Physical Layer Attacks (Layer 1)

The Physical Layer is the lowest OSI layer responsible for transmitting raw data bits through physical network hardware.

- Handles physical and electrical data transmission
- Includes cables, connectors, plugs, and receivers
- Transfers raw bits between devices
- Defines hardware standards and signal types

These attacks target **the transmission medium and signal properties**. The attacker interferes with electrical, optical, or radio signals rather than protocol logic.



Cable Tapping

Cable tapping involves **physically attaching a device to a communication cable** to intercept transmitted data.

How it works:

For copper networks:

- Attacker attaches a tapping device to twisted-pair or coaxial cable.
- The device copies electrical signals passing through the cable.
- Captured signals are decoded to reconstruct transmitted packets.

For fiber optics:

- Attacker bends the fiber slightly or uses optical splitters.
- A small portion of light leaks and is captured.
- Specialized photodetectors reconstruct the data stream.

Impact

- Confidential data interception
- Password and credential theft
- Industrial espionage

Countermeasures

- Physical security of cables
- Fiber intrusion detection systems
- Encryption (TLS, IPsec)

Types of Cable Tapping

1. Passive Tap

- Simply copies signals.
- No modification of traffic.
- Hard to detect.

2. Active Tap

- Intercepts and modifies packets.
- Can inject malicious data.

3. Optical Fiber Tap

- Uses **bending technique** to leak light signals.
- Captures optical transmissions without breaking cable.

Prevention

- Physical security of networking rooms
- Encrypted communication (TLS, SSH, IPsec)
- Fiber monitoring systems
- Tamper detection cables
- Secure cable conduits

GLA UNIVERSITY MATHURA

RF (Radio Frequency) Jamming

RF jamming is a **signal interference attack** used against wireless communication.

How it works

The attacker transmits **high-power radio signals** on the same frequency as the target system.

This causes:

- signal collisions
- noise interference
- communication failure

Typical targets

- Wi-Fi networks
- cellular communication
- Satellite links
- IoT systems

Countermeasures

- Spread spectrum techniques
- Frequency hopping
- Signal detection and monitoring

GLA UNIVERSITY MATHURA

Data Link Attacks

The Data Link Layer packages bits into **frames**, uses **MAC addresses**, and ensures **reliable transfer between two devices on the same local link**.

Data Link Layer (Layer 2) Attacks

- Target Ethernet switching mechanisms and MAC-based communication.
- Exploit weaknesses in **ARP protocol and switch forwarding tables**.
- Often used to enable **traffic interception, MITM attacks, or network disruption**.

Common Layer 2 Attacks

- MAC Flooding
- ARP Spoofing / ARP Poisoning
- VLAN Hopping
- DHCP Starvation

Key Characteristics

- Occur inside **local network segments (LAN)**.
- Exploit **lack of authentication in Layer 2 protocols**.
- Difficult to detect without **switch-level security controls**.

GLA UNIVERSITY MATHURA

MAC Flooding

A **MAC flooding attack** is a network threat that targets the limited storage of a switch's **MAC address table**. The attacker sends a large number of packets with fake or random MAC addresses, quickly filling up the table. Once it overflows, the switch can no longer forward traffic directly to the intended device. Instead, it broadcasts all incoming traffic to every port, making all data visible to connected devices and creating a major security risk.

Attack Process: The step-by-step breakdown of a MAC flooding attack is as follows:

- The attacker generates a high volume of Ethernet frames, each with a spoofed, unique MAC address.
- These frames are sent to the network switch at rapid intervals.
- The switch begins to populate its MAC address table until the storage capacity is exhausted.
- Unable to store additional entries, the switch defaults to broadcasting all traffic.

Risks associated with **MAC Flooding**:

- Traffic Sniffing
- Man-in-the-Middle Attacks
- Network Performance Degradation
- Denial of Service (DoS)

Mitigation Techniques for MAC Flooding

1. Enable Port Security on Switches

- Allow only **authorized MAC addresses** on a port.
- If an unknown MAC appears, the switch can **drop frames, restrict traffic, or shut down the port**.

This prevents attackers from injecting thousands of fake MAC addresses to overflow the switch table.

2. Limit Number of MAC Addresses per Port

- Access port normally connects to **one device** → allow 1–2 MAC addresses.
- If an attacker tries to generate hundreds of MACs, the switch detects the violation.

3. Use MAC Address Learning Limits

Switches maintain a **CAM table (Content Addressable Memory)** for MAC learning. Administrators can restrict how many addresses can be learned dynamically per port or per VLAN.

- Prevents a single port from filling the entire CAM table.
- Limits how much of the switching table an attacker can consume.

Even if an attacker sends many frames, the switch **stops learning new MAC addresses after the threshold**.

4. Implement Network Access Control (NAC):

- Only **authenticated devices** can use the port.
- Unknown devices attempting MAC flooding usually fail authentication and get placed in a **restricted VLAN or blocked network**.

GLA UNIVERSITY MATHURA

ARP Spoofing

Attacker sends **forged ARP replies** to associate their MAC address with another device's IP (often the gateway). Victims update their ARP cache and start sending traffic to the attacker, enabling **MITM, packet sniffing, or traffic modification**.

Impacts of ARP Spoofing

- **Man-in-the-Middle (MITM)** interception of traffic
- **Packet sniffing** and data theft
- **Session hijacking**
- **Traffic modification** or injection of malicious data
- **Denial of Service** if packets are dropped

Tools Commonly Used

- **Ettercap**
- **Bettercap**
- **dsniff / arpspoof**
- **Wireshark** for monitoring poisoned traffic

GLA UNIVERSITY MATHURA

How ARP Spoofing Works

1. **Normal ARP operation:** When a host wants to communicate with another device on the LAN, it sends an ARP request asking for the MAC address corresponding to an IP address.

2. **Attacker sends forged ARP replies:** The attacker sends fake ARP responses claiming that their MAC address corresponds to the IP of another device (often the router).

3. **ARP cache poisoning:** Victim machines update their ARP tables with the attacker's MAC address.

4. **Traffic redirection:** Network traffic that should go to the legitimate device is now sent to the attacker.

5. **Forwarding or manipulation:** The attacker may forward packets to the real destination to avoid detection or modify/drop packets.

GLA UNIVERSITY MATHURA

Network Layer Threats

The network layer corresponds to Layer 3 in the OSI model. Its job is **logical addressing and routing**. The protocol doing most of the work is IP. Devices such as routers operate here. Attacks at this layer target how packets are addressed and routed across networks.

Typical characteristics:

- Manipulate IP packet headers or routing behavior.
- Exploit the lack of strong authentication in basic IP mechanisms.
- Often used to hide the attacker's identity or redirect traffic.

Common examples:

- IP Spoofing
- ICMP Attacks

GLA UNIVERSITY MATHURA

IP Spoofing Attack

The attacker forges the source IP address in packets. The goal is to impersonate another host or hide the real origin. Frequently used in reflection/amplification attacks and in bypassing simple IP-based access controls.

- Attacker **forges the source IP address** in packet headers.
- Makes packets appear as if they originate from a **trusted host**.

How the Attack Works

- Attacker modifies the **source IP field** in IP packet.
- Target system believes packet is from **legitimate source**.
- Responses are sent to the **spoofed address**.

Purpose

- Hide attacker identity
- Bypass IP-based authentication
- Enable reflection or amplification attacks

GLA UNIVERSITY MATHURA

Impact and Prevention of IP Spoofing

Impact

- Enables **Man-in-the-Middle attacks**
- Used in **DDoS amplification attacks**
- Circumvents **IP filtering mechanisms**

Mitigation Techniques

- **Ingress and egress filtering**
- Router-based **packet filtering**
- **IP source validation**
- Network **intrusion detection systems**

GLA UNIVERSITY MATHURA

ICMP (Internet Control Message Protocol) Attacks

ICMP is used for diagnostics and error messages. Attackers abuse it by sending large volumes of echo requests (ping flood) or by using spoofed ICMP messages to disrupt communication or redirect traffic.

ICMP

- Used for **network diagnostics and error reporting**.
- Example tools: **ping, traceroute**.

Common ICMP Attacks

- **Ping Flood** – overwhelming target with ICMP echo requests
- **Smurf Attack** – spoofed ping sent to broadcast addresses
- **ICMP Redirect Attack** – malicious routing updates

Result

- Network congestion
- System performance degradation

GLA UNIVERSITY MATHURA

Impact and Prevention of ICMP Attacks

Impact

- **Denial of Service (DoS)**
- Network bandwidth exhaustion
- Traffic redirection in some cases

Mitigation

- **Disable unnecessary ICMP responses**
- Implement **rate limiting**
- Configure **firewall ICMP filtering**
- Use **IDS/IPS monitoring**

Transport Layer Threats

The transport layer is Layer 4. Its role is end-to-end communication between applications. The primary protocols are **TCP and UDP**. This layer handles **connection establishment, reliability, and port-based service identification**.

Attacks here usually target the way connections are created or how services listen on ports.

Typical characteristics:

- Exploit TCP connection mechanisms or UDP stateless behavior.
- Target server resources such as connection tables and buffers.
- Often used for denial of service or reconnaissance.

GLA UNIVERSITY MATHURA

SYN and UDP Flooding

SYN Flood Attack

- Exploits **TCP three-way handshake**.
- Attacker sends many **SYN requests**.
- Target allocates resources but **connections never complete**.

UDP Flood Attack

- Large volume of **UDP packets sent to random ports**.
- Target system repeatedly checks applications.

Result

- Server resources become **exhausted**.

GLA UNIVERSITY MATHURA

Impact and Mitigation of Flooding Attacks

Impact

- Service unavailability
- Server resource exhaustion
- Network congestion

Mitigation

- **SYN cookies**
- Rate limiting
- Traffic filtering
- DDoS protection systems
- Load balancing

GLA UNIVERSITY MATHURA

Port Scanning

Port Scanning

Technique used to **discover open ports and services** on a system.
Often the **first stage of network reconnaissance**.

How it Works

- Attacker sends packets to **multiple ports**.
- Observes responses to identify **open, closed, or filtered ports**.

Common Types

- TCP SYN scan
- TCP connect scan
- UDP scan

GLA UNIVERSITY MATHURA

Impact and Prevention of Port Scanning

Impact

- Reveals **running services and vulnerabilities**.
- Helps attackers plan **future exploitation**.

Mitigation

- **Firewall filtering**
- **Port access restrictions**
- Intrusion detection systems
- Disable unnecessary services

GLA UNIVERSITY MATHURA

Session & Application Layer Exploits

Session Layer (Layer 5): Responsible for:

- Establishing sessions
- Maintaining state across interactions
- Terminating sessions

Application Layer (Layer 7): Responsibilities

- Request handling
- Input processing
- Business logic execution
- Interaction with backend (DB, apis)

So, attacks here are not about packets anymore. They target:

- **State (sessions)**
- **Logic (input handling, workflows)**
- **Trust assumptions (auth, validation, sequencing)**

Session Hijacking

Session Hijacking is the act of stealing a user's "session token" (usually a cookie) to take over their active account without needing their password.

The 3-Step Process

- **Authentication:** You log into a site; the server gives you a unique Session ID.
- **The Theft:** An attacker steals that ID via **network sniffing** (on public Wi-Fi), **XSS** (malicious scripts).
- **The Takeover:** The attacker presents your ID to the server. The server thinks the attacker *is* you and grants full access.

Countermeasures:

- **Encryption:** Use **HTTPS** so the ID can't be "sniffed."
- **Cookie Security:** Use the HttpOnly flag (so scripts can't steal it) and the Secure flag (so it’s only sent over encrypted lines).
- **Rotation:** Force the browser to get a brand-new Session ID immediately after a user logs in.

Man-in-the-Middle (MITM)

A **Man-in-the-Middle (MITM)** attack is a session layer exploit where an attacker secretly relays and potentially alters the communications between two parties who believe they are directly talking to each other.

Variants
ARP poisoning (LAN)
DNS spoofing (redirect)
SSL stripping
Rogue AP (Evil Twin)

Countermeasures

- HSTS + TLS: Force clients to always use HTTPS and reject any downgrade to HTTP, preventing trivial MITM and SSL stripping.
- Certificate pinning: Client accepts only a specific server certificate or public key, blocking even valid but rogue CA-issued certificates.
- Mutual TLS (mTLS): Both client and server authenticate each other using certificates, eliminating unauthenticated endpoints.
- Network segmentation: Divide the network into isolated zones to limit lateral movement and contain compromise.

SQL Injection

A **SQL Injection** attack happens when untrusted input is embedded into SQL queries without proper sanitization, allowing the attacker to alter query structure.

Common variants

- **Union-based SQLi** → append UNION SELECT to extract data
- **Error-based SQLi** → leak info via DB error messages
- **Blind SQLi** → infer data via boolean or time-based responses
- **Second-order SQLi** → payload stored first, executed later

Countermeasures

- Prepared statements (parametrized queries)
- Least privilege DB accounts
- WAF (secondary control)

DoS / DDoS

DoS (Denial of Service): An attack where a single source overwhelms a target (server/network/app) with traffic or requests, exhausting resources and making the service unavailable to legitimate users.

DDoS (Distributed Denial of Service): Same idea, but launched from many distributed systems (botnets), making it far more scalable and harder to filter or block at the source.

Types

- **Volumetric**: bandwidth exhaustion (UDP flood)
- **Protocol**: SYN flood (state exhaustion)
- **Application layer**: HTTP flood (expensive requests)

Mitigation (in reality, not slides)

- Traffic filtering + rate limiting
- Anycast + CDN absorption
- Load balancing
- Challenge-response (CAPTCHA, proof-of-work variants)
- Upstream scrubbing (ISP / cloud mitigation)

GLA UNIVERSITY MATHURA

Botnets

A **botnet** is a network of compromised machines (bots) remotely controlled by an attacker (botmaster) to perform coordinated malicious actions.

What botnets are used for

- **DDoS attacks** (primary use case)
- **Spam campaigns**
- **Credential stuffing / brute force**
- **Cryptomining**
- **Data exfiltration / lateral movement**

Detection & mitigation

- **Network-level anomaly detection (traffic patterns, beaconing)**
- **Sinkholing C2 domains**
- **Endpoint security + patching**
- **Egress filtering (often ignored, predictably)**
- **Credential hygiene (still optional for many, apparently)**

DNS spoofing

Domain Name Server (DNS) spoofing, or DNS cache poisoning, is an attack involving manipulating DNS records to redirect users toward a fraudulent, malicious website that may resemble the user's intended destination.

Once on the fraudulent site, users are deceived into logging in to what they believe is their genuine account, thereby enabling the attacker to steal access credentials or other sensitive information. The fraudulent website can install worms or viruses on the user's computer secretively, giving the attacker sustained access to the user's device and data.

DNS Spoofing Attack Methods:

1) **MITM-based DNS Spoofing:**
2) In a MITM DNS spoofing attack, the attacker positions themselves between the victim and a legitimate DNS resolver.

Step-by-step:

- The victim sends a DNS query for www.bank.com to a legitimate DNS server.
- The attacker intercepts this query (e.g., via ARP spoofing, rogue access point, or DHCP poisoning).
- The attacker quickly crafts a forged DNS response, pretending to be the real DNS server, and sends it back to the victim *before* the legitimate response arrives.
- The victim's cache accepts the first response received. It now maps www.bank.com to the attacker's malicious IP address.
- The victim's browser connects to the fake bank site, where credentials are stolen.

Countermeasures

- Use encrypted DNS
- Enforce strict TLS certificate validation
- Network protections against local MITM
- Avoid untrusted networks / use VPNs on hostile networks

DNS Spoofing Attack Methods:

2. DNS Server Compromise based DNS Spoofing

In a DNS server compromise attack, the attacker directly takes control of or injects malicious data into an actual DNS resolver or authoritative DNS server.

Step-by-step:

- The attacker finds a vulnerability in a public or corporate DNS resolver (e.g., unpatched BIND server, weak admin password).
- Once inside, they modify the resolver's cache or zone files – for example, changing the IP address for payroll.company.com to their own server.
- All users who query that compromised resolver will receive the malicious IP address, *without any active interception on their network.*
- The attacker can harvest credentials, deliver malware, or pivot further into the internal network.

Countermeasures

- Ensures DNS responses are cryptographically verified.
- Harden DNS infrastructure
- Strong access control
- Continuous monitoring of DNS records and changes

Network Access Control (NAC)

Network Access Control (NAC) is a critical cybersecurity solution that manages access to **private networks by authenticating users and verifying device,** compliance with security policies. It enhances security by preventing unauthorized access, identifying compromised devices, and enforcing **Zero Trust principles**. Key functions include pre-admission scanning, post-admission monitoring, and quarantining devices

It

- **Prevents Unauthorized Access:** Blocks "rogue" or unknown devices from entering the corporate environment.
- **Enables Secure IoT and BYOD:** Safely manages personal employee devices by enforcing company security policies.
- **Simplified Guest Access:** Automates secure internet-only access for visitors via self-service portals.
- **Supports Zero Trust:** Continuously verifies every connection request
- **Regulatory Compliance:** Provides detailed logs and reports required for standards for audits.

NAC Core Functions and Benefits

Authentication & Authorization: Ensures only validated users and secure, authorized devices can connect.

Visibility: Provides comprehensive insight into all devices on the network, essential for BYOD and IoT management.

Policy Enforcement: Checks device health (e.g., antivirus status, patches) before granting access.

Threat Prevention: Detects and quarantines compromised devices to prevent the spread of malware.

Compliance: Helps meet regulatory requirements (e.g., HIPAA, PCI DSS) for data protection.

GLA UNIVERSITY MATHURA

NACs differ from firewalls

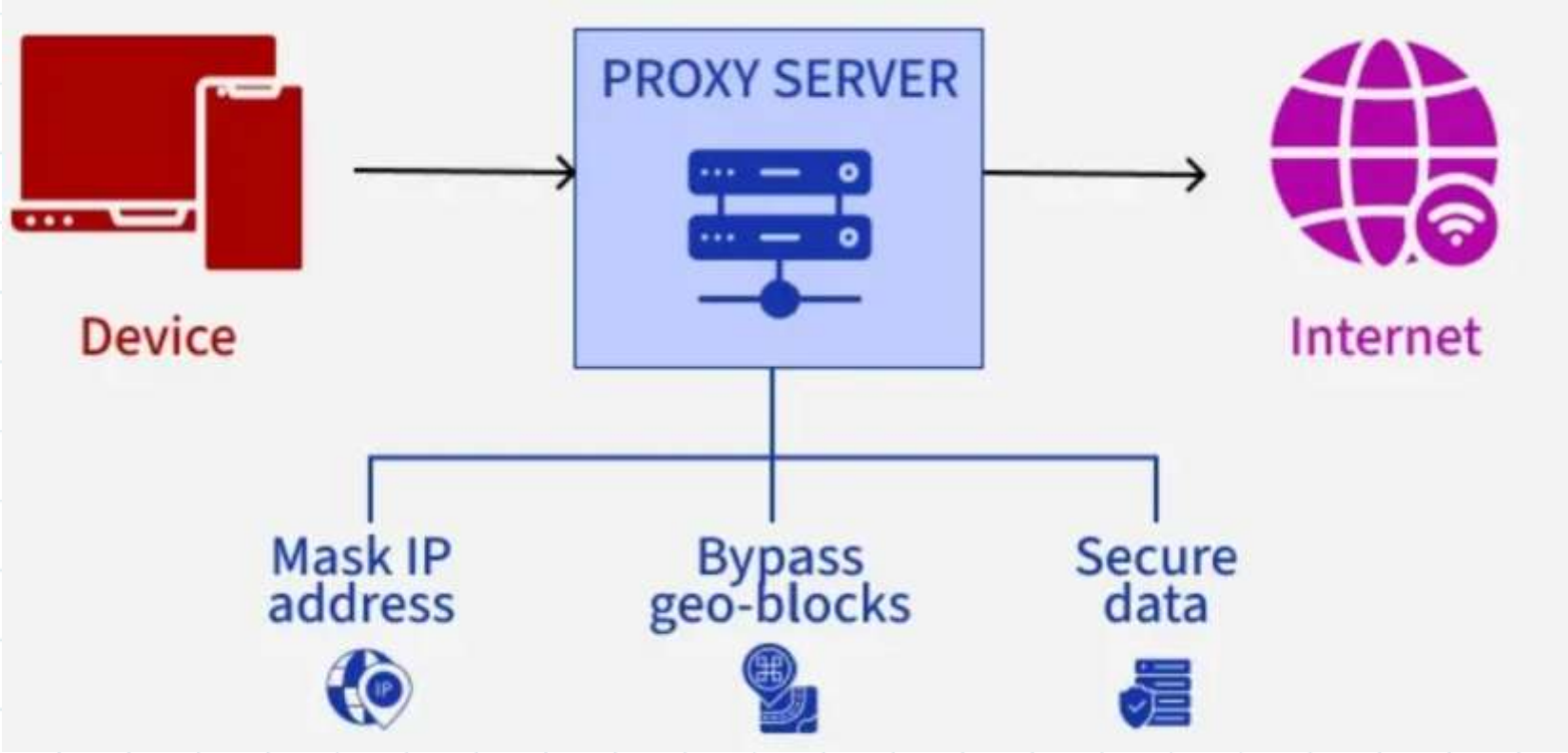
Feature	Firewall	Network Access Control (NAC)
Primary Focus	Filters data flow (traffic) based on IP, port, or protocol.	Verifies identity and compliance of devices/users.
Network Position	Acts as a perimeter gatekeeper between different networks (e.g., Internet vs. Internal).	Operates at the access layer (where devices physically or wirelessly connect).
Control Unit	Monitors "packets" and "sessions".	Manages "endpoints" and "identities".
Policy Type	Generally static rules (allow/deny).	Dynamic policies based on device "posture" (e.g., antivirus status).
Visibility	Sees traffic passing through it.	Sees every device connected to the LAN/WLAN.

GLA UNIVERSITY MATHURA

Proxy Server

A proxy server acts as a middle layer between your device and the internet, hiding your real IP address and improving online privacy. It routes your requests through another server, offering security, anonymity, and control.

- Masks your real IP address
- Filters, monitors, and controls internet traffic
- Enhances privacy and security
- Can improve speed through caching



Key Benefits of Proxy Server

1. **Privacy & Anonymity:** By masking your real IP address, proxies make it harder for websites and bad actors to track your location or identity.
2. **Bypassing Restrictions:** You can use a proxy in a different country to access content that is geoblocked in your region.
3. **Security:** Proxies can act as firewalls, filtering out malicious traffic before it reaches your private network.
4. **Performance:** Caching proxies store copies of frequently visited websites, allowing them to load faster for multiple users on the same network

GLA UNIVERSITY MATHURA